IMPROVED PASSWORD POLICY

InternCircle • Project 02 • Proposed staff policy

Purpose and scope

This policy applies to staff accounts used to access company systems, applications, email and data. It is designed to reduce password guessing, credential reuse and account takeover.

Policy rules

1. Use long passwords. Follow the system's minimum-length requirement; encourage long passphrases. For systems covered by current NIST guidance, the minimum depends on whether the password is used alone or as part of MFA.

2. Use a different password for every account. Never reuse a work password on personal websites or another work service.

3. Use an approved password manager. Generate and store unique passwords with an organisation-approved tool. Do not store passwords in plain-text documents or share them in chat.

4. Block weak and exposed passwords. Systems should reject common, predictable and known-compromised passwords. Avoid names, birthdays, keyboard patterns and simple sequences.

5. Enable multi-factor authentication (MFA). MFA is required wherever available, especially for email, administrator access, remote access and sensitive systems.

6. Do not force routine password changes without a reason. Change a password promptly when compromise is suspected or confirmed, or when instructed after an incident.

7. Allow passphrases and password-manager use. Systems should support spaces and, where technically possible, paste/autofill. Do not impose arbitrary character-type rules as a substitute for password strength.

8. Report suspicious activity. Report unexpected MFA prompts, login alerts, phishing messages or suspected password exposure to the IT/security team immediately.

Implementation and review

IT should configure password screening, support approved password managers, enforce MFA for high-risk accounts, and provide a clear reporting route. Review this policy periodically and after significant security incidents.

References

• NIST SP 800-63B — Digital Identity Guidelines

• Have I Been Pwned — Pwned Passwords

• Bitwarden — Password Manager

This is a sample student policy for the assignment. An organisation should adapt it to its systems, risk level and approved security procedures.